REMEDIACIÓN 100% COMPLETADA · VERIFICADA GAUNTLET V2

INFORME OFICIAL DE AUDITORÍA Y REMEDIACIÓN DE SEGURIDAD

Congreso de Educación Técnica Superior 2026 (DETS · GCABA)

Fecha de Emisión: 31 de Octubre de 2026
Metodología: Árbitro Adversarial (Método Gauntlet v2)
Ámbito: Backend Express API, PostgreSQL, Frontend Next.js
Estado: **10/10 Remediadas y Validadas (0 Pendientes)**

1. Resumen Ejecutivo de Auditoría y Remediación

Se completó un escaneo transversal de seguridad y la remediación integral de los **10 hallazgos detectados** sobre la arquitectura de la plataforma del Congreso ETS 2026. La evaluación auditó la integridad de autenticación, control de acceso basado en roles (RBAC/BOLA), sanitización de entradas, persistencia de medios, cifrado simétrico y normativas de protección de datos personales (Ley Nacional 25.326). Todas las vulnerabilidades fueron corregidas, verificadas mediante una batería de pruebas de integración automatizadas y validadas con compilación estricta sin errores en backend y frontend.

4	3	2	1	100%
CRÍTICAS	ALTAS	MEDIAS	BAJAS	REMEDIADO

ID	SEVERIDAD	VULNERABILIDAD DETECTADA	COMPONENTE AFECTADO	CWE / CATEGORÍA	ESTADO
SEC-01	CRÍTICA	Mutación de Roles y Catálogos Expuestos sin Autenticación	`backend/routes/admin/catalogos.routes.ts`	CWE-284 / Escalada RBAC	✓ MITIGADA
SEC-02	CRÍTICA	Cancelación Forzada de Vacantes Confirmadas sin Token/OTP	`backend/routes/usuario.routes.ts`	CWE-639 / BOLA Inseguridad	✓ MITIGADA
SEC-03	CRÍTICA	Endpoints Operativos de Acreditación y Feed en Vivo sin Auth	`backend/routes/operator.routes.ts`	CWE-306 / Missing Auth	✓ MITIGADA
SEC-04	CRÍTICA	Emisión Forzada de Certificados y Descarga Masiva de Planillas PDF	`certificados.routes.ts` & `actividades.routes.ts`	CWE-200 / Fuga Masiva PII	✓ MITIGADA
SEC-05	ALTA	Claves Secretas de Firma JWT y Cifrado AES Hardcodeadas	`lib/authService.ts` & `lib/cryptoQR.ts`	CWE-798 / Hardcoded Secrets	✓ MITIGADA
SEC-06	ALTA	Fuga de Contraseñas de Correo SMTP en Endpoint General	`routes/admin/configuracion.routes.ts`	CWE-522 / Credenciales SMTP	✓ MITIGADA

ID	SEVERIDAD	VULNERABILIDAD DETECTADA	COMPONENTE AFECTADO	CWE / CATEGORÍA	ESTADO
SEC-07	ALTA	Exposición de Token QR en Intentos Duplicados de Inscripción (409)	`backend/routes/registro.routes.ts`	CWE-200 / Fuga de Credencial QR	✓ MITIGADA
SEC-08	MEDIA	Configuración Permisiva de CORS con Credenciales Habilitadas	`backend/src/server.ts`	CWE-942 / CORS Misconfig	✓ MITIGADA
SEC-09	MEDIA	Subida de Archivos SVG sin Sanitización y Validación MIME Débil	`routes/materiales.routes.ts` & `frontend-cms`	CWE-434 / Stored XSS SVG	✓ MITIGADA
SEC-10	BAJA	Ausencia de Rate Limiting en Login y Consulta de Certificados	`routes/auth.routes.ts` & `certificados.routes.ts`	CWE-307 / Fuerza Bruta	✓ MITIGADA

2. Remediación Detallada de Vulnerabilidades Críticas (SEC-01 a SEC-04)

SEC-01: Mutación de Roles y Catálogos Expuestos sin Autenticación

`CWE-284 / CWE-269 · CRÍTICA · [REMEDIADO]`

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/routes/admin/catalogos.routes.ts`

VULNERABILIDAD ORIGINAL

El router carecía de validación de sesión en métodos de mutación. Un actor anónimo podía enviar un `POST /roles` para asignarse privilegios de Superadmin, y el listado general `GET /` exponía datos sensibles de disertantes.

✓ SOLUCIÓN TÉCNICA IMPLEMENTADA

Se incorporó `requireHierarchy(5)` en todos los endpoints de creación, modificación y borrado de roles con protección de roles esenciales del sistema (Superadmin, Administrador, Operador, Visualizador), `requireHierarchy(4)` en tipos de acreditación y categorías, y `requireHierarchy(3)` en la lectura general `GET /`. Todas las operaciones quedan registradas en la tabla inmutable `logs_auditoria`.

SEC-02: Cancelación Forzada de Vacantes Confirmadas sin Token/OTP

`CWE-639 / CWE-862 · CRÍTICA · [REMEDIADO]`

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/routes/usuario.routes.ts`, `mi-credencial/page.tsx`, `mi-identificacion/page.tsx`

VULNERABILIDAD ORIGINAL

El endpoint `POST /api/usuario/cancelar-inscripcion` solo requería el DNI del participante en el cuerpo de la petición, permitiendo a un atacante liberar vacantes de cualquier asistente sin su consentimiento.

✓ SOLUCIÓN TÉCNICA IMPLEMENTADA

Se implementó un esquema de doble factor criptográfico: ahora se exige la presentación del `qr_token` firmado emitido en la credencial digital (AES-256) o alternativamente un código OTP de 6 dígitos con expiración temporal de 15 minutos enviado al correo electrónico registrado (`POST /solicitar-cancelacion-otp`). Las vistas frontend envían automáticamente el `qr_token` del usuario.

SEC-03: Endpoints Operativos de Acreditación y Feed en Vivo sin Auth

`CWE-306 · CRÍTICA · [REMEDIADO]`

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/routes/operator.routes.ts`

VULNERABILIDAD ORIGINAL

El módulo de acreditación en puestos de acceso permitía acreditar participantes y emitir walk-ins sin autenticación JWT obligatoria, confiando ciegamente en un campo `operador_id` enviado por el cliente.

✓ SOLUCIÓN TÉCNICA IMPLEMENTADA

Se aplicó `router.use(requireHierarchy(3))` a nivel global de todo el router de operadores. La identidad del operador se extrae estrictamente del token JWT firmado del usuario autenticado (`req.operator.sub`), imposibilitando la suplantación de operadores en las auditorías de acceso.

SEC-04: Emisión Forzada de Diplomas y Descarga Masiva de Planillas PDF

`CWE-200 / CWE-862 · CRÍTICA · [REMEDIADO]`

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/routes/certificados.routes.ts` & `backend/src/routes/actividades.routes.ts`

VULNERABILIDAD ORIGINAL

Cualquier visitante podía forzar la emisión manual de certificados institucionales con horas de capacitación arbitrarias mediante `POST /api/certificados`, y descargar planillas PDF completas con el padrón de asistentes a salas sin autenticación.

✓ SOLUCIÓN TÉCNICA IMPLEMENTADA

Se aplicó `requireHierarchy(4)` en la emisión y manipulación de diplomas institucionales, y `requireHierarchy(3)` en la generación y descarga de planillas oficiales de sala (`GET /:id/planilla-pdf`).

3. Remediación de Vulnerabilidades Altas, Medias y Bajas (SEC-05 a SEC-10)

SEC-05: Claves Secretas de Firma JWT y Cifrado AES Hardcodeadas

`CWE-798 · ALTA · [REMEDIADO]`

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/lib/authService.ts`, `backend/src/lib/cryptoQR.ts`, `backend/src/lib/db.ts`

✓ SOLUCIÓN TÉCNICA IMPLEMENTADA

Se eliminaron todos los fallbacks débiles y credenciales por defecto. Se implementó un fail-safe estricto: si `JWT_SECRET` o `ENCRYPTION_KEY` no están configurados en el entorno (con un mínimo de 32 bytes requeridos para AES-256), el backend interrumpe su ejecución con un error fatal descriptivo impidiendo el inicio inseguro.

SEC-06: Fuga de Contraseñas de Correo SMTP en Endpoint General

`CWE-522 · ALTA · [REMEDIADO]`

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/routes/admin/configuracion.routes.ts`

✓ SOLUCIÓN TÉCNICA IMPLEMENTADA

El endpoint `GET /api/admin/configuracion` ahora enmascara y sanitiza los objetos de conexión SMTP en `cuentas_correo`, reemplazando las contraseñas en texto claro por `********` si existen configuradas, evitando la exposición inadvertida en el panel de administración.

SEC-07: Exposición de Token QR en Intentos Duplicados de Inscripción (409)

`CWE-200 · ALTA · [REMEDIADO]`

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/routes/registro.routes.ts`

✓ SOLUCIÓN TÉCNICA IMPLEMENTADA

Se eliminaron los campos `qr_token` y `usuario_id` del cuerpo de respuesta con código HTTP 409. Ante un intento duplicado, el servicio informa de forma neutral que el participante ya se encuentra registrado sin entregar credenciales ni identificadores internos.

SEC-08: Configuración Permisiva de CORS con Credenciales Habilitadas

`CWE-942 · MEDIA · [REMEDIADO]`

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/server.ts`

✓ SOLUCIÓN TÉCNICA IMPLEMENTADA

Se configuró una lista blanca estricta con coincidencia exacta (`ALLOWED_ORIGINS`). Se erradicó el fallback permisivo y la coincidencia genérica por subcadena de Railway. Todo origen no autorizado es bloqueado formalmente con `callback(new Error('CORS origin denied'))`.

SEC-09: Subida de Archivos SVG sin Sanitización y Validación MIME Débil

`CWE-434 / CWE-79 · MEDIA · [REMEDIADO]`

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/lib/fileSecurity.ts`, `materiales.routes.ts`, `frontend-cms.routes.ts`, `server.ts`

✓ SOLUCIÓN TÉCNICA IMPLEMENTADA

Se creó el módulo `fileSecurity.ts` que realiza verificación de magic bytes para imágenes (JPEG, PNG, GIF, WebP, PDF) y sanitización XML profunda para archivos SVG, eliminando nodos `<script>`, atributos de eventos inline (`onload`, `onerror`, etc.) y esquemas `javascript:`. Asimismo, se incorporó cabecera CSP restrictiva en la entrega de archivos estáticos.

SEC-10: Ausencia de Rate Limiting en Login y Consulta de Certificados

`CWE-307 · BAJA · [REMEDIADO]`

UBICACIÓN Y ARCHIVOS AFECTADOS

`backend/src/routes/auth.routes.ts` & `backend/src/routes/certificados.routes.ts`

✓ SOLUCIÓN TÉCNICA IMPLEMENTADA

Se implementaron limitadores de peticiones basados en `express-rate-limit`: `loginLimiter` (máximo 10 intentos por ventana de 15 minutos en inicio de sesión) y `certificadosLimiter` (máximo 30 consultas por minuto en la verificación pública de certificados).

4. Certificación de Verificación Ejecutable (Método Gauntlet v2)

En estricto cumplimiento del Método Gauntlet v2, todas las remediaciones fueron sometidas a validación sintáctica, compilación tipada estricta y ejecución de una suite de pruebas de seguridad automatizada:

VECTOR DE PRUEBA	COMANDO / SUITE DE VERIFICACIÓN	RESULTADO
Compilación Backend	`cd backend && npm run build` (TypeScript 5.x)	✓ 0 ERRORES
Verificación de Tipos Frontend	`cd frontend && npx tsc --noEmit` (Next.js 16)	✓ 0 ERRORES
Batería Automatizada SEC-01 a SEC-10	`test_suite_all_security.ts` (10/10 Vectores de Ataque)	✓ 100% PASADO
Pre-Push Adversarial Hook	Inspección de secretos, builds y cero placeholders	✓ VALIDADO

Dictamen Final del Árbitro Adversarial: La plataforma del Congreso ETS 2026 cuenta con un esquema de seguridad robusto, con autenticación y autorización jerárquica estricta, protección contra ataques de inyección, mitigación de abuso mediante rate limiting, aislamiento de secretos institucionales y garantía de integridad en datos de los participantes según las normativas vigentes.

Árbitro Adversarial • Auditoría y Remediación de Seguridad DETS

Dirección de Educación Técnica Superior • Ministerio de Educación • GCABA • Documento Oficial Aprobado